SAMPLE · ILLUSTRATIVE · NOT LEGAL ADVICE

AI Use Policy (concise edition)

Example Relief Foundation · 60 staff · humanitarian NGO (invented for illustration)

Owner	Approved by	Version	Effective	Next review	Applies to
AI Steward (Head of Operations)	Director	1.0	1 Nov 2026	1 May 2027	All staff, consultants, volunteers, on any device or account

> **How to read this sample.** This is the four-page edition of a sample policy M.A.I. Consulting shows to clients. A client's own version keeps the same structure and replaces the illustrative names, tools and seats with its own; the full edition adds the role annexes, the approved-tool register and the record templates. Nothing here is legal advice or a certification.

1. Purpose and scope

This policy says what people doing the Foundation's work may do with AI tools, with which data, on which tools, and what they must check, log and disclose. It applies on every device and account, including personal accounts and free tools: a task done for the Foundation is inside this policy. "AI tool" means any software that generates, summarises, translates, classifies or acts on content from a prompt, including assistants built into office software and agents that act in other systems. The Foundation uses AI systems and does not build them; it is a deployer under the EU AI Act, whose Article 4 asks deployers to support AI literacy. This policy, the training record and the playbooks are those measures. They are documentation, not a certification.

2. Five terms

Term	Meaning here
Approved tool	A tool listed in the approved-tool register, on the stated plan and settings. The free tier of an approved tool is not approved.
Input	Anything typed, pasted, uploaded, dictated or connected to a tool, including files it may read.
Output	Anything a tool returns or does: text, tables, translations, summaries, actions in another system.
Personal and beneficiary data	Anything that identifies or could identify a living person, alone or in combination. Beneficiary data is always Class 4.
Agent	A tool configured to plan and carry out several steps in other systems before returning. It may read, write or send; which is set per task.

3. Permitted uses (permissions come first)

Each permission names the task, the safeguard and the data boundary. A task not listed is asked of the AI Steward; for Class 1 or 2 data the default answer is yes and the task is added at the next revision. In every case the input contains no Class 3 or 4 data unless the row says otherwise, every figure, name, date and rule is checked against the source, and the person who sends or files the result is its author of record.

Who	May use an approved tool to	Safeguard and boundary
All staff	Draft, summarise, restructure, rewrite in plain language, translate for review, prepare meeting notes and follow-ups; research public sources.	Four checks before reliance; every citation opened before it is quoted; output is a lead until verified.
Programmes	Draft donor narrative reports from internal notes and the previous report.	No beneficiary name, case identifier or location below district level; figures verified against the results file before the draft leaves the department.
Fundraising	Draft proposals against a funder template; build eligibility checklists from a call; summarise public information on institutional funders.	No figure accepted without recomputation against the budget file; no profile of a named individual.
Finance and admin	Draft budget narratives from the spreadsheet; procurement comparison tables; procedures.	No bank, payroll, supplier-identifier or unpublished financial data; the tool's arithmetic is never the figure.

Who	May use an approved tool to	Safeguard and boundary
Human resources	Draft job descriptions, interview question banks, staff-facing policy explanations, onboarding material.	No candidate or employee personal data; no screening, selection, performance or disciplinary judgement informed by output.
Communications	Draft press releases, social copy, briefing notes from long reports, first-draft translations.	Nothing published without a named owner and a source check; translations reviewed sentence by sentence by a bilingual reader.
Leadership	Summarise board papers; draft decision memos with options; scenario notes.	The decision, the rejected option, the risk owner and the sign-off are written by the accountable person; AI assistance is stated on the paper.

4. Red lines

Inputs that never enter any tool: personal or beneficiary data (Class 4) unless clause 5 allows it; case files, referrals, safeguarding reports, grievances, medical or legal details about any person; unpublished financial statements, draft budgets, bank, payroll and supplier identifiers, passwords, tokens and keys; donor or partner information received in confidence and anything marked Confidential or Restricted by its source; anything at all in a tool that is not approved.

Decisions never delegated. No tool output decides, is the sole basis for, or is configured to act on: eligibility for assistance and its ending or reduction; safeguarding judgements and referrals; hiring, promotion, discipline, grievance outcomes and ending employment; authorisation of any payment, contract, statement or account; public statements on live or contested matters and crisis communications; legal positions and anything submitted to a court, regulator or authority. A person decides and their name is on it. The list is short on purpose; everything else is governed by clause 3 and the four checks.

5. Data classification

Every document and prompt falls into one of four classes. The test is one question: **who is harmed if this appears somewhere it should not?** In doubt between two classes, use the higher; in doubt whether something identifies a person, treat it as Class 4.

Class	Definition	Examples	May enter
1 · Public	Already published. Nobody is harmed by disclosure.	Annual report, public funder guidelines, legislation, press releases	Any approved tool, including web search
2 · Internal	Unpublished; disclosure would inconvenience, not harm.	Procedures, templates, meeting notes without personal data, aggregated indicators	Approved tools on the organisational plan, never a free tier
3 · Confidential	Disclosure would harm the Foundation, a partner or a funder.	Unpublished financials, draft budgets, partner agreements, donor correspondence, security plans	Only tools marked Class 3 in the register, inside a restricted Project or workspace
4 · Restricted	Disclosure would harm a person. All personal and beneficiary data.	Case files, beneficiary lists, HR records, health or legal status, images and voices, locations below district level	No AI tool, unless covered by a listed data processing agreement, recorded in the register by the Data Protection Focal Point, and de-identified where the task allows

A data protection impact assessment is run before any new use involving Class 4 data, profiling of individuals, automated decisions about people, or a new tool that reads Class 3 or 4 data by connector. The Data Protection Focal Point decides whether it is triggered.

6. Approved tools

The register lists each approved tool with the plan, account type, required settings (training on inputs off, retention, sharing defaults), the highest data class it may receive, the owner and the review date. A tool is approved for a plan and settings, not as a brand. Staff use their Foundation account; a personal account is allowed only for Class 1 and is logged. New tools and features climb the trust ladder before real work: sandbox on Class 1 data, a named owner, a test on the Foundation's own documents, a check against this policy, then a listing. The AI Steward keeps a tool inventory of what staff actually use, refreshed before each review and built in an amnesty spirit: reporting a tool is never penalised.

7. Verification: the four checks

Check	Question	Fails when
Figures	Can every number be traced to a source document I can point at?	A figure appears that is in no source. The commonest and most expensive error.
Facts	Are names, dates, rules and citations checked against the original, not the summary?	A rule is quoted from the summary; a citation is cited unopened.
Language	Read once for tone and for deficit-based or stereotyping wording about the people we serve.	A phrase we would not use about a person in the room.
Defensibility	Would I say this sentence out loud to the funder, the board or the community?	The honest answer is no.

The checks run before any AI-assisted output is relied on, sent, filed or published, and the person can show they ran them. Checking time counts as work time; if checking exceeds the time saved, the task goes in the "do not use AI" column of the playbook. For translation the check is sentence-by-sentence bilingual review; for monitoring data it is that no outlier was dropped, no gap filled and no causal claim added.

8. Disclosure

Funder submissions state AI assistance in the form agreed with the funder, naming the task and the safeguard, for example: "the first draft of the narrative section was prepared with an AI tool from internal notes; all figures were verified against the results table by the programme officer." Board papers state where AI assisted and who wrote the decision. Published material is disclosed where the channel, funder or law requires it, and always when substantially generated rather than drafted and rewritten. Communication to beneficiaries never uses AI-generated images or voices of real or realistic people, and any AI-drafted message to a beneficiary is reviewed by the person who would have written it. Vague disclosure ("AI was used") and over-disclosure that implies a tool made a human judgement are both avoided.

9. Agents, connectors and automation

Before an agent or connector touches any system, its owner writes its blast radius: everything it could reach on its worst day and the worst wrong action it could take. Access is granted per task, not per agent; read, write and send are separated. Default is read-only. Write access needs review before output takes effect; send access (email, payments, publishing, deletion) needs the Director's written approval. Browser agents inherit the logged-in session and are not used where irreversible or Class 3 and 4 actions are available. Everything an agent reads is untrusted and may carry instructions aimed at it, so agents read only from curated sources and listed folders, never from shared mailboxes or ticket queues unless approved. No agent, Skill or automation runs on real work without a named owner who is not only its builder, a one-page operating guide, a passed test set and a listing in the permissions record; a set-up with no owner is switched off at the next review. The decisions in clause 4 are never configured into an agent.

10. Records

Record	What is written	Who and where
One-line log	Tool · task · date · disclosure needed yes/no, for any AI-assisted task that leaves the department.	Each person; department log in the shared folder.
Decision ledger	Four lines where output shaped a decision about a person, a funder or a public position: what the tool contributed, what the person decided differently, who signed, where the output is kept.	Accountable person; kept for the life of the decision plus the funder's retention period.
Near-miss log	Notice · name · narrow, for anything that nearly went wrong. No penalty attaches to an entry.	Anyone; read at every review.
Training record	Who attended which session, when, what was covered, at what level, including consultants and volunteers.	AI Steward; with the policy, tool inventory, readiness scores and review record it forms the evidence file a board, funder or auditor asks for.

11. Escalation and the 24-hour rule

The escalation contact is the AI Steward; for anything involving personal data, the Data Protection Focal Point. Names and deputies are on the intranet front page. Escalation-worthy is defined broadly: Class 3 or 4 data entered into a tool, an unapproved tool used on Class 2 or above, an output relied on that proved wrong after it left the building, an agent action nobody intended, a prompt that produced instructions from a document, or any doubt at all. Within 24 hours of discovery the person tells the contact, by any channel, what happened, what data, which tool and what has been done; the contact

decides within the same 24 hours whether it is contained, whether the data breach procedure starts and who else is told. Reporting is never penalised; failing to report is a conduct matter. Every incident and near miss ends in a recorded change: a clause, a setting, a playbook line or a training gap.

12. Training, competence and ownership

Every person completes the general session on this policy and the four competencies (Delegation, Description, Discernment, Diligence) within three months of joining and before using an approved tool on Class 2 data or above. The training floor is level 3 of the seven capability levels: a full brief, grounded in the real document, the four checks and the log. Staff who build set-ups for others (level 6) are named as champions in the training record. Five seats own AI at the Foundation: the **Sponsor** (Director: approves the policy and send permissions), the **AI Steward** (Head of Operations: policy, tool inventory, training record, review), **Use Owners** (one per department: playbook and its set-ups), **Champions** (staff at level 4 or above: questions and office hours) and the **Assurer** (Data Protection Focal Point: data classes, impact assessments, incidents).

13. Review

The AI Steward reviews this policy every six months with the Use Owners and the Data Protection Focal Point against four questions: did anyone need a rule that was not here; did a rule get routed around; did a tool, plan or setting change; did the law or a funder's requirement change. An earlier review is triggered when the escalation contact leaves, an approved tool changes its data terms or adds a feature touching a data class, the same escalation occurs twice, or the law or a major funder's requirements change. Playbooks are revised the week an exception appears; the register is updated whenever a tool changes; the readiness re-score at six months is read alongside the review. The reason behind each boundary is kept in a one-line rationale ledger so the "why" survives changes of staff and tools.

14. Relationship to law and standards

This policy sits under the Foundation's data protection policy; where they differ, the stricter rule applies, and the impact-assessment trigger test and breach procedure are that policy's. Under the EU AI Act the Foundation is a deployer; clause 12 and the training record are its AI-literacy measures, and no use it operates has been assessed as high-risk. The structure borrows from the NIST AI Risk Management Framework and ISO/IEC 42001 as checklists at a size proportionate to 60 people, without any claim of conformity or certification. Where a funder's own AI or data rules are stricter, they apply to that grant.

Prepared by M.A.I. Consulting as an illustrative sample. The Example Relief Foundation does not exist. A client's policy is drafted from its readiness assessment and tool inventory and is reviewed by its own legal and data protection advisers before adoption.